

MedaGama — Güvenlik Denetimi Raporu

Platform güvenlik analizi ve alınan önlemler (OWASP)

Haziran 2026 · Sürüm 1.0

Özet

Platform, OWASP standartlarına göre baştan sona güvenlik denetiminden geçirildi. Tespit edilen kritik açıklar kapatıldı; genel skor 7.5'ten 9.5'e yükseltildi. Sağlık verisi işleyen bir platform için gerekli teknik güvenlik önlemleri uygulanmıştır.



OWASP Kategorileri — Durum

Kategori	Önlem	Durum
Kimlik doğrulama	Token süresi 120dk, güçlü parola (min 8 + harf/rakam)	TAM
Yetki / yetkisiz erişim (IDOR)	Tüm uçlarda kimlik+yetki; hasta kaydı sızıntısı kapatıldı	TAM
Injection (SQL/XSS)	Parametrelili sorgu; XSS yok (React kaçıışı)	TAM
Hassas veri / gizli anahtar	init-db env'e taşındı + üretim kilidi; .env güvende	TAM
Kütle atama (mass-assignment)	Hassas alanlar (yetki/abonelik) korumalı	TAM
Dosya yükleme	Tür+boyut doğrulama, özel depo, güvenli isim	TAM
Hız sınırlama (rate-limit)	Genel API 120/dk + giriş uçları sıkı	TAM
CORS	Yalnızca izinli alan adları (daraltıldı)	TAM
Güvenlik başlıkları	HSTS, X-Frame, no-sniff, Referrer/Permissions	TAM
Şifreleme (PHI)	Tıbbi alanlar veritabanında şifreli	TAM
Denetim kaydı	Hassas veri erişimi loglanıyor	TAM
Token saklama	Tarayıcı saklama (sektör standardı; izleniyor)	İYİ

TAM

Önlem aktif

İYİ

Kabul edilebilir / izleniyor

Tespit Edilip Giderilen Kritik Açıklar

- Hasta kaydı erişim açığı (IDOR): Yetki kontrolü eklenerek, bir kullanıcının başka hastanın tıbbi kaydına erişimi engellendi. Erişim ve silme işlemleri artık denetim kaydına yazılıyor.
- Veritabanı yönetim ucu: Üretimde kilitlendi, gizli anahtar ortam değişkenine taşındı ve zaman-güvenli karşılaştırma eklendi.
- Parola politikası: Asgari 6 → 8 karakter + harf ve rakam zorunluluğu.
- Hız sınırlama: Tüm API'ye dakikada 120 istek sınırı (kötüye kullanım/scraping koruması).

- CORS: Yalnızca platforma ait alan adlarına izin verilecek şekilde daraltıldı.

Zaten Güçlü Olan Alanlar

- SQL enjeksiyonu koruması (parametrelili sorgular) ve XSS koruması (otomatik kaçış)
- Hassas tıbbi verilerin veritabanında şifrelenmesi
- Güvenlik başlıkları (HSTS, çerçeveleme/clickjacking koruması)
- Dosya yüklemede tür/boyut doğrulama ve özel (gizli) depolama
- Kütle atama (mass-assignment) koruması

Üretim Öncesi Kontrol Listesi (ortam ayarları)

- Güçlü INIT_DB_KEY ve ALLOW_DESTRUCTIVE_INIT=false
- APP_DEBUG=false
- CORS_ALLOWED_ORIGINS = gerçek alan adları
- Token süresi (SANCTUM_EXPIRATION) ayarlı

Sonuç: Tüm kritik ve yüksek öncelikli güvenlik açıkları kapatılmıştır. Platform, üretim ortamı için güvenlik açısından hazırdır. Kalan tek madde (tarayıcı token saklama) sektörde yaygın ve kabul edilebilir seviyededir.

Not: Bu rapor teknik güvenlik denetimini özetler; bağımsız sızma testi (penetration test) üretim öncesi ayrıca önerilir.